

Incident Report — INC-0134

"The Compromised Identity"

Lab 3 of 3 · Advanced · Service Principal · Key Vault · Conditional Access

3 Security Gaps Found	3 Gaps Remediated	P1 Severity Level	SC-300 + AZ-500 Cert Alignment
---------------------------------	-----------------------------	-----------------------------	--

Ticket	INC-0134 — CRITICAL SECURITY INCIDENT
Severity	P1 — Active Breach Risk
Reported By	Elena V. — CISO + SIEM Alert
Engineer	Alan — Azure Security Engineer
Tools Used	Azure CLI · PowerShell · Entra Admin Center
Cert Alignment	SC-300 — Identity · AZ-500 — Security

The Incident

"Alan — we have a P1 security incident. Three things flagged simultaneously:

- 1. Our webapp service principal has Owner rights at subscription level. A web app should NEVER have Owner.*
- 2. Our Key Vault is wide open — no RBAC, legacy access policies, no firewall, weak soft delete. Production secrets are exposed.*
- 3. Conditional Access shows a gap — MFA policy exists but is in Report-only mode. Nobody is actually being required to do MFA."* — Elena V., CISO

What I Found and Fixed

PROBLEM 1 Over-Privileged Service Principal

SYMPTOM

Webapp service principal lab3-webapp-sp had Owner role at subscription scope. Owner = full admin over everything in the subscription.

ROOT CAUSE

A web app only needs to read one secret from Key Vault. Owner at subscription level means the app could delete any resource, assign any role, or access any data across the entire subscription — a massive blast radius if the SP credentials were ever compromised.

FIX

Removed Owner role at subscription scope using az role assignment delete. Assigned Key Vault Secrets User scoped only to the specific Key Vault using az role assignment create. SP now has exactly what it needs — nothing more.

PROBLEM 2 Key Vault Security Misconfiguration

SYMPTOM

Key Vault had RBAC disabled (using legacy Access Policies), network firewall open to all networks, and soft delete retention set to only 7 days.

ROOT CAUSE

Legacy Access Policies are harder to audit than RBAC. Open network means anyone on the internet could attempt to reach the vault. 7-day soft delete means secrets deleted by mistake or maliciously could be permanently lost within a week.

FIX

Enabled RBAC authorization using az keyvault update --enable-rbac-authorization true. Locked network to Deny all by default using --default-action Deny. Documented soft delete as a deployment-time finding — Azure does not allow changing retention after creation.

PROBLEM 3 🔑 Conditional Access MFA Not Enforced

● SYMPTOM

Conditional Access policy Require-MFA-All-Users existed but was in Report-only state. This means it was only logging what WOULD happen — not actually enforcing MFA on anyone.

🔍 ROOT CAUSE

Report-only mode is used for testing a policy before enabling it. Leaving it in this state indefinitely means the entire tenant has no MFA enforcement. Three suspicious sign-in attempts from unknown locations were detected during this window.

✅ FIX

Disabled Security Defaults (required before enabling custom CA policies). Changed policy state from Report-only to On in Entra Admin Center. MFA is now enforced for all users including guests.

✅ Verification Results

#	What Was Verified	How Verified	Result
1	SP no longer has Owner at subscription	<code>az role assignment list --assignee --all</code>	✅ Key Vault Secrets User only
2	RBAC enabled on Key Vault	<code>az keyvault show --query enableRbacAuthorization</code>	✅ True
3	Key Vault network locked down	<code>az keyvault show --query networkAcls.defaultAction</code>	✅ Deny
4	MFA enforced via Conditional Access	Entra Admin Center – Policy state	✅ On
5	Soft delete finding documented	Cannot change after creation – noted for next deployment	❑ Documented

🏆 Key Takeaways

What this lab teaches that hiring managers look for:

🏆 A service principal should only have the minimum role needed for its specific job. Owner at subscription = full admin = catastrophic if credentials leak.

 **Key Vault RBAC is the modern standard. Legacy Access Policies are harder to audit and manage. Always enable RBAC on new Key Vaults.**

 **Report-only mode in Conditional Access is for testing only. A policy in Report-only enforces nothing. Always verify the State is On in production.**

 **Soft delete retention must be set correctly at deployment time. Azure does not allow changing it after creation. Set it to 90 days in Bicep before deploying.**

 **Security Defaults and Conditional Access cannot coexist. Enterprise environments disable Security Defaults and use CA policies for full control over authentication.**

The Story:

I received a P1 security incident with three simultaneous findings. The first was a webapp service principal with Owner rights at subscription scope — I confirmed this using `az role assignment list` with the `--all` flag which shows assignments across all scopes. I removed the Owner role and replaced it with Key Vault Secrets User scoped only to the specific Key Vault the app needed.

The second finding was a Key Vault with multiple misconfigurations. It was using legacy Access Policies instead of RBAC, the network firewall was open to all networks, and soft delete retention was only 7 days. I enabled RBAC authorization and locked the network to Deny by default using `az keyvault update`. I documented the soft delete issue as a deployment-time finding since Azure does not allow changing retention after creation.

The third finding was a Conditional Access policy in Report-only mode — which means it was monitoring but not enforcing anything. To enable it I first had to disable Security Defaults which conflicts with custom CA policies. I then switched the policy to On, enforcing MFA for all users immediately.

All three findings were verified with CLI commands and portal screenshots. The incident was closed with the SP scoped correctly, Key Vault hardened, and MFA actively enforced across the tenant.